

Lecture 38 : Network Based Attacks

(Part I)

Introduction

In the realm of cybersecurity, understanding network-based attacks is paramount, especially for those involved in penetration testing and network defense. This lecture delves into the fundamental concepts and technologies exploited by attackers to compromise network infrastructure and services. By examining the mechanics of these attacks, we gain crucial insights into how they are executed and, more importantly, how they can be effectively prevented. This foundational knowledge is essential for anyone looking to secure digital assets in an increasingly interconnected world.

This session specifically focuses on Denial of Service (DoS) attacks, which aim to make a service unavailable to its legitimate users. We will explore three distinct types: the Smurf DoS attack, the Ping of Death, and the SYN flooding attack. While the Ping of Death is not strictly a DoS attack, it shares the objective of disrupting system availability. These attacks highlight common vulnerabilities in network protocols like ICMP and TCP, demonstrating how seemingly innocuous features can be weaponized. As attackers grow more sophisticated, equipped with advanced tools, a robust understanding of these attack vectors becomes indispensable for developing resilient defense strategies.

Core Concepts

Term	Definition	Significance
Denial of Service (DoS)	An explicit attempt by an attacker or group to prevent legitimate users from accessing a network service or resource.	The primary objective of many network attacks, aiming to disrupt availability and functionality.
Distributed Denial of Service (DDoS)	A more dangerous and effective form of DoS where multiple compromised computer systems attack a single target, overwhelming it.	Amplifies the impact of a DoS attack, making it harder to mitigate due to distributed sources.

Term	Definition	Significance
ICMP (Internet Control Message Protocol)	A core protocol in the TCP/IP suite used for sending error messages and operational information between network devices.	Exploited in attacks like Smurf DoS and Ping of Death due to its echo request/reply functionality.
IP Spoofing	The act of creating IP packets with a false source IP address to conceal the sender's identity or impersonate another system.	Crucial for many DoS attacks, allowing attackers to hide their origin and direct responses to a victim.
Broadcast Address	A special IP address used to send a packet to all hosts on a specific network segment simultaneously.	A key component of the Smurf DoS attack, enabling amplification of traffic directed at a victim.
TCP 3-way Handshake	The process by which a TCP connection is established, involving SYN, SYN-ACK, and ACK packets exchanged between client and server.	The fundamental weakness exploited by SYN flooding attacks, leading to resource exhaustion.
Half-Open Connection	A state on a server where a TCP connection has received a SYN packet and sent a SYN-ACK, but has not yet received the final ACK.	The critical resource consumed and exhausted by SYN flooding attacks, leading to service denial.
SYN Cookie	A cryptographic technique used to protect against SYN flooding by deferring state allocation until the full 3-way handshake is complete.	An effective mitigation strategy that prevents servers from being overwhelmed by spoofed connection requests.

Detailed Analysis

1. Denial of Service (DoS) Attacks

Denial of Service (DoS) attacks represent a significant threat to network availability, aiming to make a service inaccessible to its intended users. This can be executed by a single attacker or a group, targeting various network infrastructures or services like web servers, mail servers, or application servers. The core objective is to overwhelm the target system or its network resources, preventing legitimate users from establishing connections or receiving responses.

A more potent variant is the Distributed Denial of Service (DDoS) attack, where multiple compromised computers (often referred to as "bots" or "zombies") coordinate to launch an attack. This distributed nature makes DDoS attacks far more dangerous and effective, as the sheer volume of traffic from numerous sources can quickly bring down even robust systems. The frequency, severity, and sophistication of these attacks have increased over time, necessitating advanced defense mechanisms. For service owners, adequate protection is crucial to prevent such attacks from being easily mounted.

2. Smurf Denial of Service Attack

The Smurf DoS attack exploits the Internet Control Message Protocol (ICMP), a fundamental part of the TCP/IP suite. ICMP is primarily used for sending error messages and for diagnostic purposes, such as determining if a host is available using an ICMP Echo Request (ping) and expecting an ICMP Echo Reply.

The attack leverages this echo and reply feature in a specific way:

- * **ICMP Echo Request:** The `ping` command, commonly available on most machines, generates ICMP Echo Request packets. When you `ping` an IP address, an echo request is sent, and if the target is available, an echo reply is returned, providing network statistics like latency.

- * **Exploiting Broadcast Addresses:** In a Smurf attack, the attacker sends an ICMP Echo Request packet to a network's broadcast address. A broadcast address is a special IP address (typically with all ones in the host part) that ensures the packet is delivered to every computer within that network segment.

- * **IP Spoofing:** Crucially, the attacker uses IP spoofing to change the source IP address of the ICMP Echo Request packet to that of the victim (the target they wish to attack).

- * **Amplification:** When the broadcast-enabled network receives this spoofed ICMP Echo Request, every machine in that network segment will respond with an ICMP Echo Reply. However, because the source IP was spoofed to be the victim's address, all these reply packets are directed back to the victim.

* **Flooding the Victim:** If the network has a large number of machines (e.g., 10,000 computers), the victim will be flooded with an equivalent number of ICMP Echo Reply packets. This massive influx of unsolicited traffic overloads the victim's network interface, consumes its processing resources, and fills its network buffers, effectively denying service to legitimate users. Legitimate packets may be discarded due to full buffers, leading to a denial of service.

Mitigation: A primary defense against Smurf attacks is to configure edge routers in every network to reject external packets that have a broadcast address as their destination. By preventing such packets from entering the network, the amplification mechanism of the Smurf attack is neutralized.

3. Ping of Death Attack

The Ping of Death is another attack that utilizes ICMP ping messages, though its objective is more about crashing or rebooting a system rather than a pure denial of service through traffic volume.

* **Normal Ping Packet Size:** Typically, ICMP Echo Request and Reply packets are small, well under the maximum allowed IP packet size of 65,536 bytes (64 kilobytes).

* **The Attack:** In a Ping of Death attack, an attacker deliberately crafts an ICMP echo packet that is larger than this maximum allowed size.

* **Fragmentation and Reassembly:** When such an oversized packet is sent, the IP layer fragments it into multiple smaller IP packets for transmission across the network. Upon reaching the destination, these fragments are reassembled.

* **System Vulnerability:** The vulnerability arises during the reassembly process. If the target system's operating system or network stack is not robustly designed to handle an IP packet that, once reassembled, exceeds the maximum permissible size, it can lead to unexpected behavior. This might include the system crashing, freezing, or even rebooting.

* **Mounting the Attack (Example):** On a Linux machine, an attacker could use a command similar to this:

```
ping -f -s 65537 [target_IP_address]
```

Here, `-s 65537` specifies a packet size greater than 65536 bytes, and `-f` instructs the system to send packets as quickly as possible, increasing the likelihood of overwhelming the target.

* **Importance of Rate:** The rate at which these oversized packets are sent is crucial. If sent too slowly, the target might recover or handle them without crashing. However, if sent rapidly, it can quickly fill buffers and trigger the vulnerability.

It's important to note that modern operating systems and network devices are generally patched against the classic Ping of Death vulnerability, but misconfigurations or unpatched legacy systems can still be susceptible.

4. SYN Flooding Attack

SYN flooding is a classic Denial of Service attack that exploits a weakness in the TCP 3-way handshake protocol, which is used to establish a connection between a client and a server.

*** TCP 3-way Handshake:**

1. **SYN:** The client sends a SYN (synchronize) packet to the server, requesting to establish a connection.
2. **SYN-ACK:** The server responds with a SYN-ACK (synchronize-acknowledge) packet, acknowledging the request and sending its own synchronization request.
3. **ACK:** The client sends a final ACK (acknowledge) packet, completing the handshake, and the connection is established.

*** The Attack Mechanism:**

*** Spoofed SYN Packets:** An attacker sends a large number of SYN packets to the target server. Crucially, these SYN packets have spoofed source IP addresses. This means the source IP address in the packet header is falsified, often pointing to non-existent or unreachable hosts.

*** Half-Open Connections:** When the server receives a SYN packet, it allocates resources (e.g., memory for connection state, a new thread) and sends back a SYN-ACK packet to the spoofed source IP. Since the source IP is spoofed, the SYN-ACK goes to an address that did not initiate the connection, and thus, no ACK packet is ever returned to the server.

*** Resource Exhaustion:** The server maintains these "half-open connections" in its memory, waiting for the final ACK packet, typically until a timeout period elapses. By continuously sending spoofed SYN packets, the attacker fills the server's connection table and pending request queue with these half-open connections.

*** Denial of Service:** Once the server's resources for managing connections are exhausted, it can no longer accept new legitimate connection requests. Even valid clients attempting to connect will find their requests blocked or rejected, leading to a denial of service.

*** Asymmetry of Cost:** A key aspect of SYN flooding is the asymmetry of resource allocation. The attacker expends minimal resources (just sending a packet), while the server allocates significant resources (memory, CPU cycles for a new thread) for each half-open connection. This imbalance makes the attack highly effective.

Mitigation: SYN Cookies:

One effective defense against SYN flooding is the use of SYN cookies. This technique modifies the TCP handshake process to prevent the server from allocating resources

for a connection until the client has proven its legitimacy.

1. **SYN Packet:** Client sends a SYN packet to the server.
2. **SYN-ACK with Cookie:** Instead of storing the connection state in its memory, the server computes a "cookie" (a cryptographic hash or encrypted value) based on the client's source IP, port, destination IP, port, and a secret server key. It then sends a SYN-ACK packet back to the client, with the cookie embedded in the sequence number field. The server does not store any state for this half-open connection.
3. **ACK with Cookie:** If the client is legitimate, it will receive the SYN-ACK, extract the cookie, and send back an ACK packet with the cookie value.
4. **Cookie Verification:** Upon receiving the ACK, the server recomputes the cookie using the information from the ACK packet and its secret key. If the recomputed cookie matches the one received in the ACK, the server knows it's a legitimate client that successfully completed the second step of the handshake. Only then does the server allocate resources and establish the connection.

This method ensures that the server only allocates resources for connections that have successfully completed the initial two steps of the handshake, effectively mitigating the resource exhaustion caused by spoofed SYN packets.

Key Takeaways

- [] Denial of Service (DoS) attacks aim to prevent legitimate users from accessing network services.
- [] Distributed Denial of Service (DDoS) attacks amplify DoS by using multiple compromised systems.
- [] The Smurf DoS attack exploits ICMP Echo Request/Reply by sending spoofed requests to a network's broadcast address, flooding the victim with replies.
- [] IP spoofing is a critical technique in Smurf and SYN flooding attacks to hide the attacker's identity and direct responses to the victim.
- [] Configuring edge routers to block external packets with broadcast destinations is a key defense against Smurf attacks.
- [] The Ping of Death attack involves sending an ICMP packet larger than the maximum allowed size, which can cause vulnerable systems to crash or reboot upon reassembly.
- [] SYN flooding attacks exploit the TCP 3-way handshake by sending numerous SYN packets with spoofed source IPs, creating "half-open connections" that exhaust server resources.
- [] The asymmetry of resource allocation (attacker low cost, server high cost) is central to the effectiveness of SYN flooding.

- [] SYN cookies are an effective mitigation for SYN flooding, deferring server state allocation until the client proves legitimacy by returning a valid cookie.
- [] Understanding the underlying protocol weaknesses (ICMP, TCP) is crucial for both mounting and defending against network-based attacks.

Conclusion

This lecture has provided a foundational understanding of several prominent network-based attacks, specifically focusing on Denial of Service techniques. We've seen how the Smurf attack leverages ICMP and broadcast addresses for amplification, how the Ping of Death exploits packet size limits to crash systems, and how SYN flooding overwhelms servers by exploiting the TCP 3-way handshake with spoofed requests. Each of these attacks highlights critical vulnerabilities in widely used network protocols, demonstrating that even seemingly benign features can be weaponized.

The discussion on mitigation strategies, such as configuring edge routers for Smurf attacks and implementing SYN cookies for SYN flooding, underscores the importance of proactive defense mechanisms. As network infrastructures continue to evolve, so too will the sophistication of attacks. A deep comprehension of these attack vectors is not just academic; it is a practical necessity for network administrators, security professionals, and anyone responsible for maintaining the integrity and availability of digital services. The next lecture will build upon this foundation by exploring more advanced attack types, including distributed denial of service attacks, and further delve into their practical implications and countermeasures.